

RESULTS · 21 JUL 2026

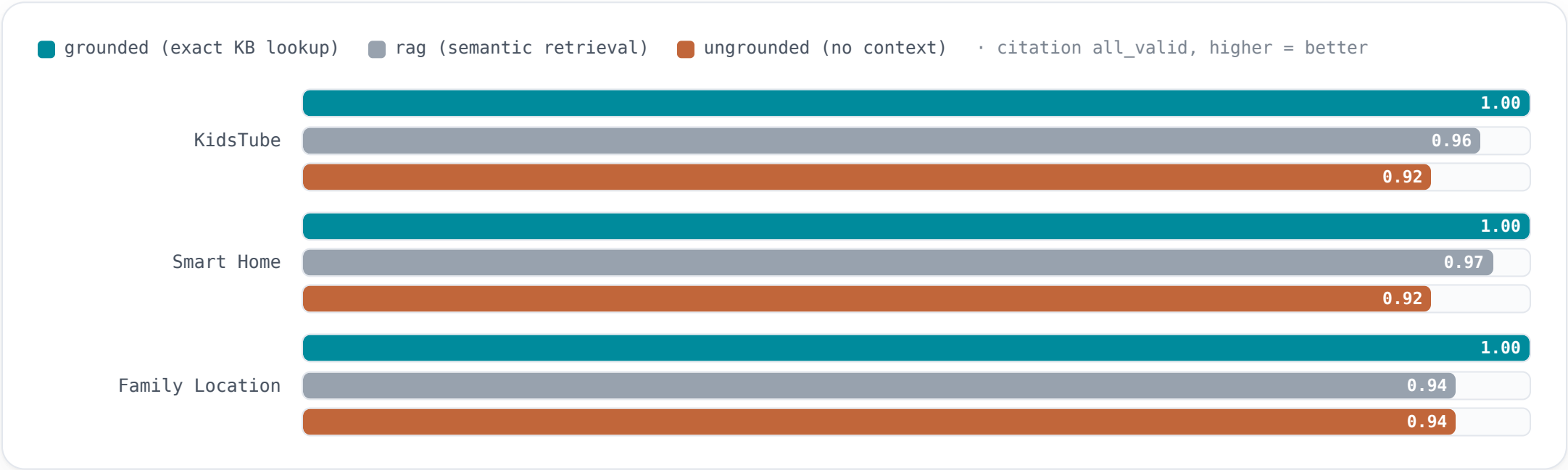
An LLM can cite a source it **never actually read**.

Trustworthy AI privacy threat
modeling depends not on traceability
that is **claimed**, but on traceability
that is **verified** — every citation
re-derived against the source, not
trusted from the model's own output.

Deterministic grounding makes a citation verifiable by construction

Every generated threat cites the LINDDUN threat-tree node it instantiates and the DFD location where it arises. We re-check both against the knowledge base after generation. Across three scenarios and three grounding modes, the ordering never breaks.

All LLM generation in these results uses [Azure gpt-5.4](#).



Grounded = 1.00 everywhere, grounded > rag > ungrounded every time. The model cannot cite a node or location that isn't real when the context it's handed is an exact lookup rather than a similarity search or its own memory.

Threat-generation scores against the LINDDUN gold

Each scenario is elicited under all three grounding pipelines and matched threat-by-threat against its expert-style gold catalog. All three scenarios are fully Process-mediated, so reachability-adjusted recall equals raw recall (nothing is structurally unreachable).

LINDDUN FRAMEWORK · TYPE + SAME-FLOW MATCH									
SCENARIO	PIPELINE	N_GEN	GOLD	TP	FP	FN	PREC	RECALL	F1
KidsTube	GROUNDED	118	41	32	86	9	0.27	0.78	0.40
	RAG	82	41	23	59	18	0.28	0.56	0.37
	UNGROUNDED	109	41	28	81	13	0.26	0.68	0.37
Smart Home	GROUNDED	56	18	16	40	2	0.29	0.89	0.43
	RAG	38	18	8	30	10	0.21	0.44	0.29
	UNGROUNDED	53	18	15	38	3	0.28	0.83	0.42
Family Location	GROUNDED	114	20	19	95	1	0.17	0.95	0.28
	RAG	69	20	13	56	7	0.19	0.65	0.29
	UNGROUNDED	83	20	14	69	6	0.17	0.70	0.27

GENOMIC · PANOPTIC FRAMEWORK (REFERENCE, GOLD = 99)								
PIPELINE	N_GEN	TP	FP	FN	PREC	RECALL	F1	
GROUNDED	172	19	153	80	0.11	0.19	0.14	
RAG	100	19	81	80	0.19	0.19	0.19	
UNGROUNDED	212	12	200	87	0.06	0.12	0.08	

- **Grounded leads recall in every scenario** — and is the only pipeline that also holds 1.00 citation validity.
- Precision is the automated **lower bound**: gold catalogs are curated, not exhaustive, and no manual FP adjudication has run yet.

Source code → DFD, derived three ways

The adapter turns the KidsTube repository into a Data Flow Diagram, in three arms that mirror the pipeline's own grounded / RAG / ungrounded ablation one level up. The only thing that changes between them is **how a citation is allowed to be written**.

BASELINE

facts_only

No LLM. A DFD assembled deterministically from parsed code facts. The bar the model must clear.

`cite → fact id`

CLOSED VOCABULARY

llm

The model reads the resolved fact list and cites a **fact id from a closed, provided set**. An id either resolves or it doesn't.

`cite → fact id`

THE ABLATION

llm_naive

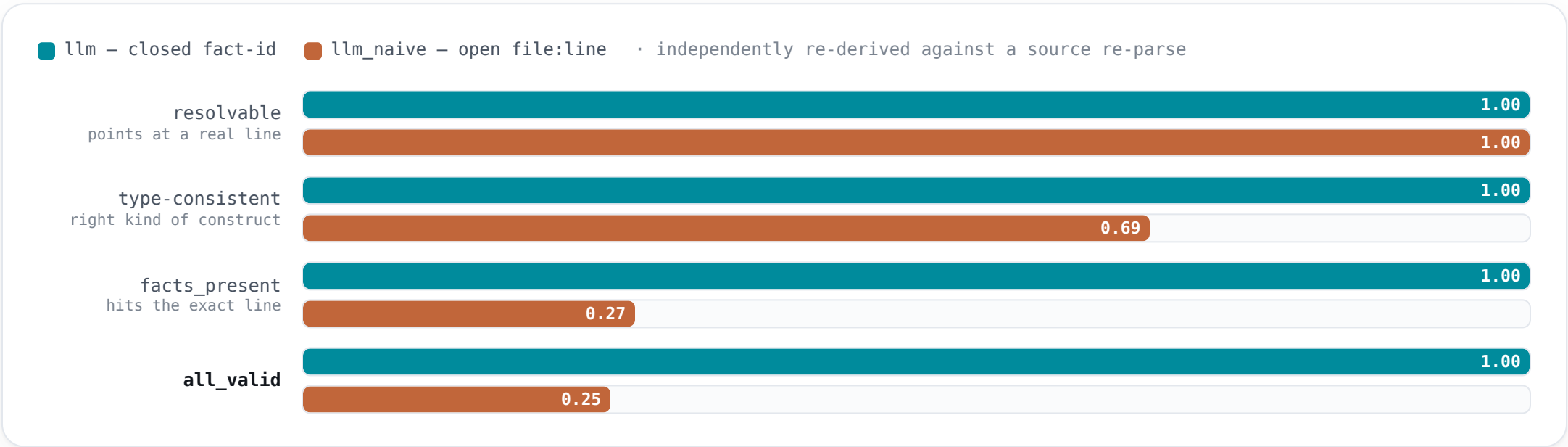
The model reads **raw source** and self-reports {file, line}. Open vocabulary, **no confabulation guard**.

`cite → file : line`

llm_naive is the adapter-level analogue of ungrounded: a file:line is a self-report that can point anywhere. It exists to measure what citation validity does

Open citations don't get fabricated — they get **un-verifiable**

1.00 → **0.25**
closed vocab · all_valid open vocab · all_valid



The open citations point at a real source line **100%** of the time — nothing is hallucinated — but land on the *exact* construct line only **27%** of the time. Real, but not deterministically verifiable: accepting them needs fuzzy matching, which reintroduces the judgment the fact-id vocabulary removes.

READING IT HONESTLY

Two things the open arm did that we did **not** predict

OVER-PRODUCTION

It draws far too many flows

The naive arm emits ≈ 45 flows against the hand DFD's 17, and its element precision falls to 0.35 (the llm arm holds 0.77). Removing deterministic grounding costs modeling quality, not just citation quality.

A PREDICTION THAT FAILED

It didn't confabulate the planned features

We expected the guard-free arm to invent P4 (AI engine) and EE3 (advertisers) — the two elements in no code. It didn't: the ceiling held at 2 every run. It over-decomposed *implemented* code instead. Reported as it came out.

The llm arm and facts_only sit at 1.00 citation validity *by construction* — a closed, provided vocabulary makes a bad citation impossible. That number was vacuous until this open arm existed to contrast it against. Now it means something.

Deriving the DFD from source costs recall, not citation validity

We generated threats on the code-derived DFD and scored them against the hand baseline restricted to the same 27 anchorable gold threats — apples to apples, the flows the derived DFD structurally lacks removed from both sides.



CITATION ALL_VALID · HAND → DERIVED		
grounded		1.00 → 1.00
rag		0.96 → 0.99
ungrounded		0.92 → 0.94
Every cited node, type and location still resolves — the derived DFD is a valid anchor target. Grounding order holds on both DFDs.		

Traceability's payoff is **verifiability**, and it depends on the vocabulary

An `file:line` self-report looks fine until you check it — real lines, wrong precision, 0.25 verifiable. A closed fact-id vocabulary is 1.00 verifiable *because a fabricated id cannot resolve*. That difference is the whole argument for re-derived, not asserted, citations.

- **Does the vocabulary matter?** Open-vocabulary citation validity collapses 1.00 → 0.25; the decomposition (resolvable 1.00, present 0.27) is the case for fact ids.
- **Does automating the DFD hurt?** A code-derived DFD costs recall (0.70 → 0.52 grounded) but preserves citation validity (1.00 → 1.00).
- **Next.** Generate threats on the `llm` and `llm_naive` DFDs; add a span-tolerant citation check to bracket the 0.27; first FP-adjudication pass.